

Incident Response, Forensics & Cyber Laws

Chapter 5



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Incident Response Life Cycle

Cyber Incident Response Life Cycle

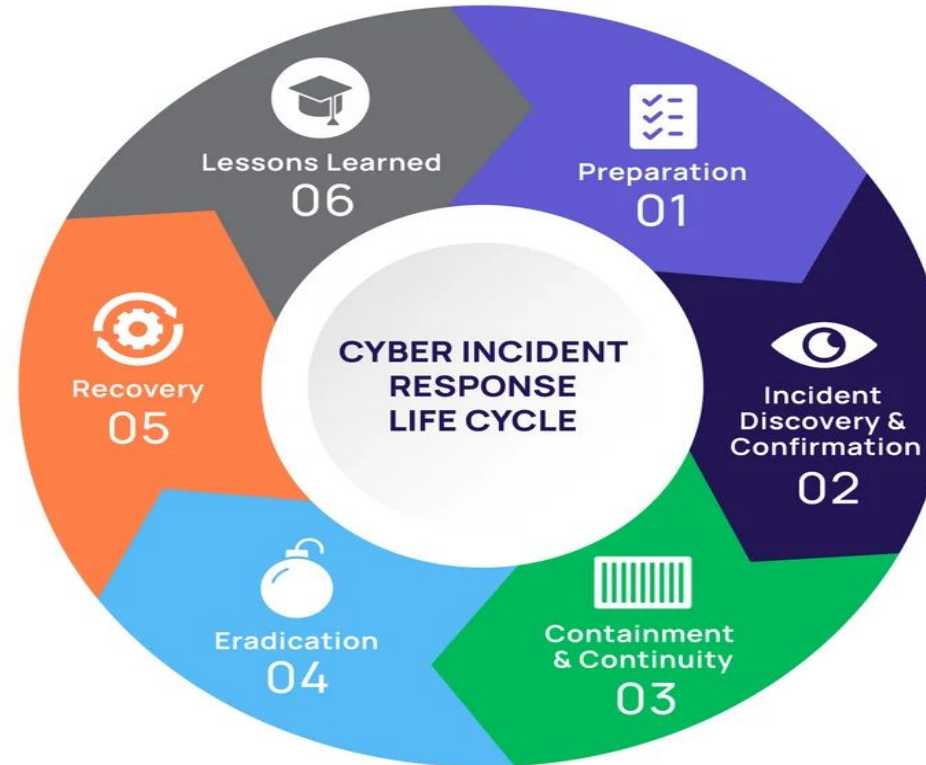


image: delineam.com/resources/free-incident-response-plan-template



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



- **1. Preparation**

- This is the planning stage before any incident occurs. Organizations build their defense and readiness.
- Create incident response policies and procedures
- Train staff and form an Incident Response Team (IRT)
- Install security tools (firewalls, IDS/IPS, antivirus)
- Conduct risk assessments and drills
- Goal: Be ready to act quickly and effectively.

- **2. Detection & Analysis**

- Identifying whether an incident has occurred and understanding its scope.
- Monitor logs, alerts, and unusual activities
- Use SIEM tools to detect threats
- Analyze the type, source, and severity of the incident
- Confirm if it's a real attack or false alarm
- Goal: Detect incidents early and accurately.

- **3. Containment**
 - Limit the damage and prevent the spread of the attack.
 - Isolate affected systems (disconnect from network)
 - Disable compromised accounts
 - Apply temporary fixes (patches, blocks)
 - Two types:
 - **Short-term containment** (immediate action)
 - **Long-term containment** (temporary solutions until full fix)
 - Goal: Stop the attack from getting worse.
- **4. Eradication**
 - Remove the root cause of the incident.
 - Delete malware or malicious files
 - Remove unauthorized access or backdoors
 - Fix vulnerabilities (patch software, update configs)
 - Goal: Completely eliminate the threat.

- **5. Recovery**

- Restore systems to normal operation.
- Restore data from backups
- Monitor systems for any signs of recurrence
- Gradually reconnect systems to the network
- Goal: Safely resume business operations.

- **6. Lessons Learned**

- Analyze the incident and improve for the future.
- Document what happened and how it was handled
- Identify gaps in security or response
- Update policies, tools, and training
- Goal: Prevent similar incidents in future.

Computer Emergency Response Team (CERT)

- Computer Emergency Response Team (CERT) is a group of experts dedicated to handling cybersecurity incidents. In the context of network management, the **Computer Emergency Response Team (CERT)** plays a key role in helping organizations to protect and defend against cyber threats, vulnerabilities, and incidents.



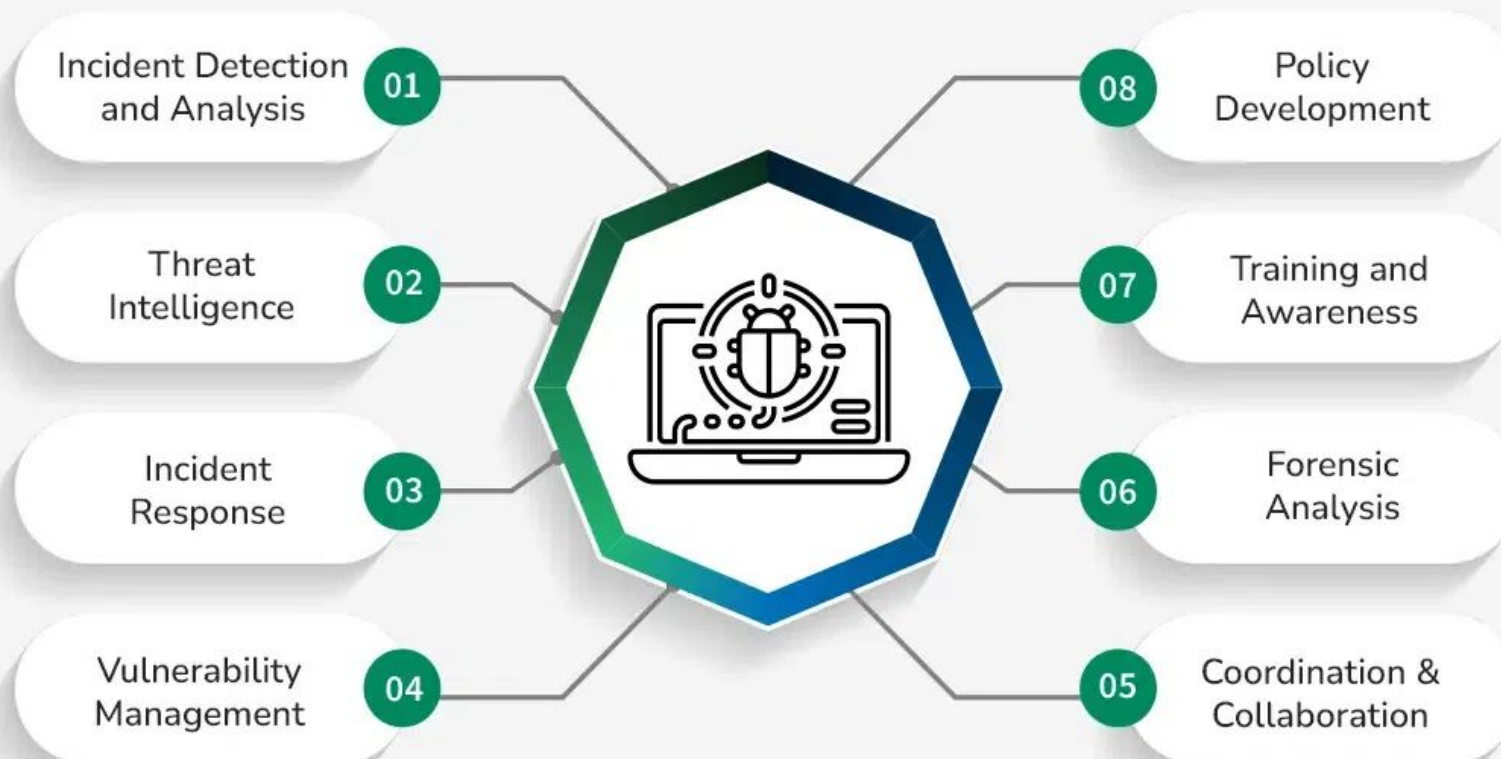
SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering





CERT



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Roles and Responsibilities of CERT

- **Incident Detection and Analysis:** Monitoring systems and networks for potential security breaches and promptly identifying malicious activities.
- **Incident Response:** Taking swift and coordinated actions to contain and mitigate the impact of cybersecurity incidents, such as data breaches or malware infections.
- **Threat Intelligence:** Gathering, analyzing, and disseminating information about current and emerging cyber threats to enhance proactive defense measures.
- **Vulnerability Management:** Identifying and addressing vulnerabilities in software, hardware, and network infrastructure to prevent exploitation by [malicious](#) actors.
- **Coordination and Collaboration:** Working closely with internal teams, external partners, law enforcement agencies, and regulatory bodies to coordinate incident response efforts effectively.
- **Forensic Analysis:** Conducting thorough investigations post-incident to determine the root cause, assess the extent of damage, and recommend remedial actions.
- **Training and Awareness:** **Educating employees and stakeholders about cybersecurity best practices**, raising awareness about potential threats, and promoting a culture of security within the organization.
- **Policy Development:** Developing and implementing [cybersecurity policies](#), procedures, and guidelines to establish a robust security framework.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Key Digital Forensics Techniques

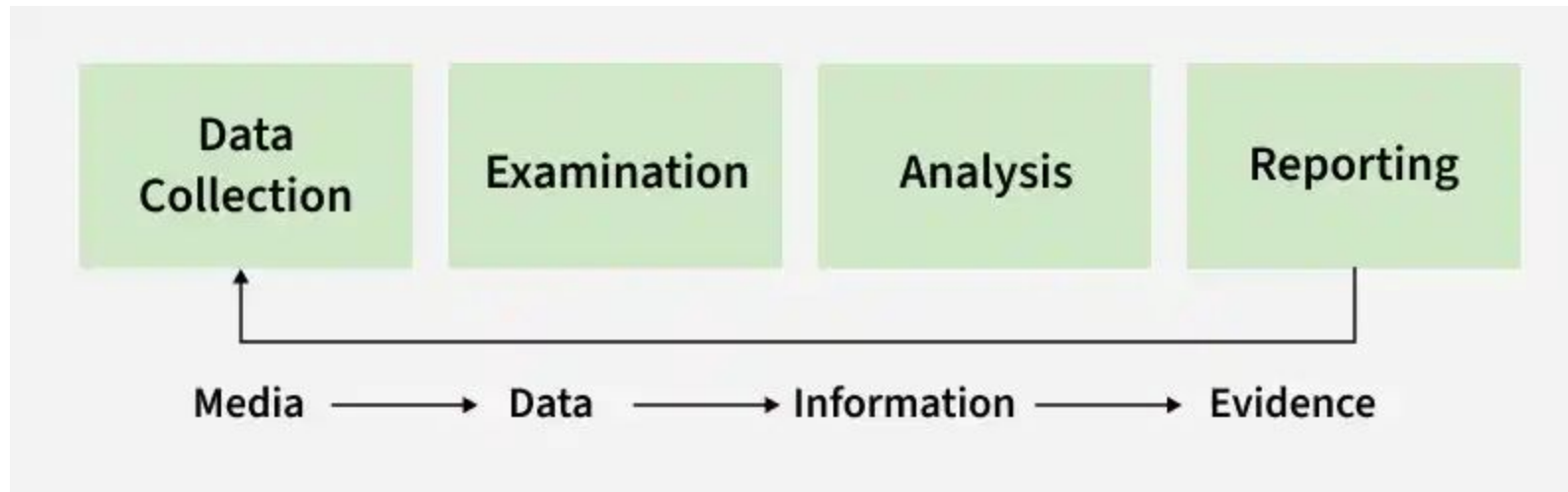
- **Disk Imaging/Acquisition:** Creating bit-by-bit copies of storage media (e.g., hard drives, USBs) to preserve original data, often using FTK Imager or dd.
- **File Carving:** Recovering deleted files or fragments from unallocated disk space without relying on file system metadata.
- **Memory Forensics:** Analyzing volatile memory (RAM) to extract information about running processes, network connections, and encryption keys.
- **Live Data Acquisition:** Capturing data from a running system before shutting it down to prevent the loss of volatile evidence.
- **Network Forensics:** Monitoring and analyzing traffic to track malicious activity, using tools like Wireshark.
- **Email & Keyword Analysis:** Searching through emails and metadata to trace communication and recover deleted messages.
- **Reverse Steganography:** Detecting hidden data within images or other files.

Top Digital Forensics Tools

- **Autopsy:** An open-source, GUI-based platform for analyzing disk images and generating reports.
- **Magnet AXIOM:** An advanced platform for collecting and analyzing evidence from computers, smartphones, and cloud services.
- **EnCase:** A widely used, comprehensive commercial tool for data collection and analysis.
- **Volatility Framework:** A popular tool for advanced, in-depth memory forensics.
- **FTK Imager:** Used for creating fast, secure forensic images of files and drives.
- **Bulk Extractor:** Scans disk images to extract useful information like URLs and email addresses.
- **Wireshark:** A network protocol analyzer for examining live traffic.

Evidence Collection

- Digital evidence in cyber forensics refers to electronic data collected and analyzed to investigate cybercrimes and legal cases. It helps forensic experts identify, preserve, and present digital information from computers and other electronic devices.

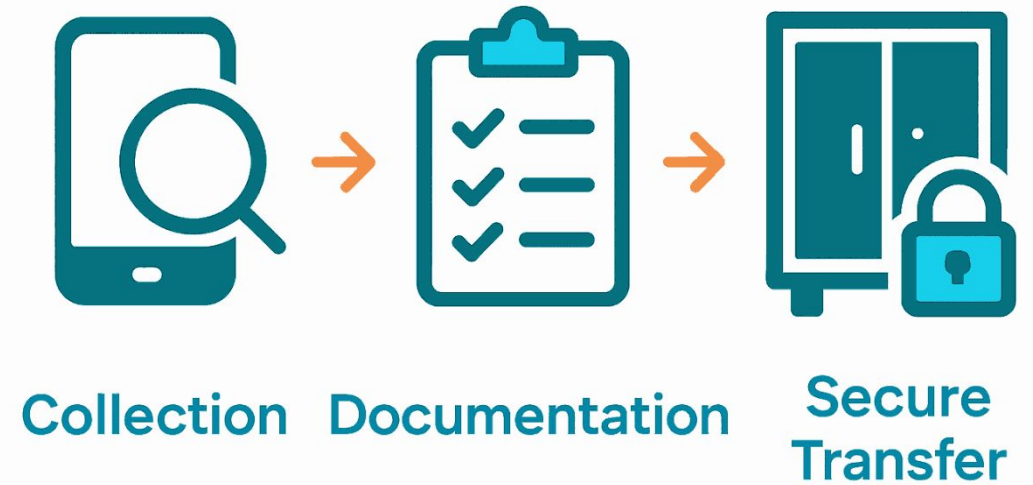


- **Data Collection**
 - Identify sources of digital evidence.
 - Collect data from devices such as computers, mobiles, servers, or storage media.
 - Ensure original data is not modified during collection.
 - Use forensic tools to create copies of evidence.
- **2. Examination**
 - Carefully inspect the collected data.
 - Filter relevant information related to the investigation.
 - Detect hidden, deleted, or encrypted files.
 - Organize data for further analysis.
- **3. Analysis**
 - Use forensic techniques to interpret evidence.
 - Identify patterns, relationships, or suspicious activities.
 - Reconstruct events using collected data.
 - Extract useful information that supports the investigation.
- **4. Reporting**
 - Document all findings clearly and accurately.
 - Present evidence in structured format.
 - Include details of tools and methods used.
 - Prepare report for legal authorities or organizations.

Chain of custody

- Chain of custody in digital forensics is the chronological, documented record of evidence handling, from seizure to court presentation.
- It ensures digital evidence remains authentic, unaltered, and admissible by tracking who accessed, transferred, or analyzed it.
- Key steps include identifying, securing, documenting, hashing, and storing data securely to prove its integrity.

Chain of Custody



Key Components of Digital Chain of Custody

- **Documentation:** Detailed, step-by-step logs of every person who handled the evidence, along with the date and time of transfer.
- **Unique Identifier:** Assigning unique IDs to every piece of evidence (e.g., hard drives, cloud logs).
- **Hashing:** Using cryptographic algorithms to create a unique file signature (like a fingerprint), ensuring that even a tiny change to the evidence is detectable.
- **Storage and Security:** Physical and digital safeguarding of evidence to prevent unauthorized access or tampering.

Steps in the Chain of Custody Process

- **Collection:** Evidence is collected, and a detailed record of the device, location, and person collecting it is created.
- **Preservation:** Evidence is protected from alteration (e.g., placing phones in Faraday bags, imaging hard drives).
- **Documentation:** The [Chain of Custody Form](#) must accompany the evidence throughout the investigation.
- **Analysis:** Analysis is conducted on a copy of the original data, not the original itself.
- **Presentation:** Evidence is presented in court, where the documentation proves that the evidence is in the same condition as when it was collected.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



- **Consequences of a Broken Chain**

A failure to maintain this record (e.g., unauthorized access, gaps in documentation) can render evidence unreliable and inadmissible in court, allowing cases to be dismissed.

Information Technology Act, 2000 (IT Act)

- The Information Technology Act, 2000 (IT Act) is India's primary cyber law that provides a legal framework for electronic transactions, digital governance, and the prevention of cyber crimes.
- Establishes legal recognition for electronic records and digital signatures
- Promotes secure online transactions and e-governance
- Defines cyber offences and prescribes penalties
- Protects individuals and organisations from cyber threats
- Regulates intermediaries and digital platforms

Key Features of the IT Act

- **1. Digital Signatures**
 - Provides legal recognition to electronic signatures in digital transactions.
 - Ensures the authenticity and integrity of online contracts and documents.
- **2. Cybercrime Regulation**
 - Defines and penalizes offenses like hacking, identity theft, cyber terrorism, and cyber stalking.
 - Provides legal protection and remedies for victims of cybercrimes.
- **3. Cyber Cafes**
 - Defines cyber cafes as public places offering internet access for a fee.
 - Requires proper user identity records and compliance with security guidelines.
- **4. Overriding Provisions**
 - IT Act provisions take precedence over conflicting laws in cyber matters.
 - Ensures harmony without affecting rights under other acts like the Copyright Act, 1957.
- **5. Regulation of Digital Media**
 - Introduces rules for regulating social media and digital content platforms.
 - Focuses on user safety, grievance redressal, and data privacy compliance.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Important Sections and Their Penalties

- The IT Act has different sections that deal with different cyber offenses. Here's an overview of some important ones:

Section	Offense	Penalty
Section 43	Unauthorized access or damage to computer systems	Compensation for damages to the system owner
Section 66	Hacking a computer system	Up to 3 years in prison or ₹5 lakh fine or both
Section 66B, C, D	Fraud and identity theft	Up to 3 years in prison or ₹1 lakh fine or both
Section 66E	Violation of privacy by transmitting private images	Up to 3 years in prison or ₹2 lakh fine or both
Section 66F	Cyber terrorism threatening India's sovereignty, integrity, or security	Life imprisonment
Section 67	Publication of obscene content online	Up to 5 years in prison or ₹10 lakh fine or both



SOM
VIDYAVIHAR

K J Somaiya College of Engineering



Digital Personal Data Protection (DPDP) Act

- The [Digital Personal Data Protection \(DPDP\) Act, 2023](#), enacted in August 2023 and strengthened by the DPDP Rules, 2025, creates a framework for protecting digital personal data in India.
- It regulates data processing—online or offline if digitized—by ensuring lawful use, consent, and user rights, with penalties for breaches.
- The law applies to data processing within India and outside if offering goods/services to residents.

Key Highlights of the DPDP Act, 2023

- **Data Principal Rights:** Individuals (Data Principals) have the right to access, correct, erase, and withdraw consent for their data.
- **Data Fiduciary Obligations:** Entities handling data (Data Fiduciaries) must provide notice, obtain clear consent, ensure data accuracy, and delete data once the purpose is met.
- **Child Protection:** Processing data of individuals under 18 requires parental consent, and targeting children with harmful advertising is prohibited.
- **Significant Data Fiduciaries (SDF):** The government can designate certain entities as SDFs, requiring them to appoint a data protection officer, conduct impact assessments, and independent audits.
- **Penalties:** Data breaches can lead to substantial penalties, with fines up to ₹250 crore for failure to prevent data breaches.
- **Data Protection Board of India:** A regulatory body will be established to monitor compliance, hear grievances, and impose penalties.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



International Cyber-Security laws/frameworks – GDPR, HIPAA

- GDPR and HIPAA are critical, distinct cybersecurity regulations: GDPR is a broad EU regulation protecting personal data for any entity handling EU resident data, while HIPAA is a U.S. law focusing specifically on securing patient health information (PHI) within the American healthcare industry.
- Both mandate strict data protection and breach reporting, often requiring specialized compliance frameworks like ISO 27001 or NIST.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Key International Cybersecurity Regulations

- **GDPR (General Data Protection Regulation):**
 - **Scope:** Protects personal data of EU/EEA residents.
 - **Application:** Extraterritorial; applies to any organization worldwide that processes EU resident data.
 - **Requirements:** Lawful basis for processing, privacy notices, 72-hour breach notification, and strict data subject rights.
 - **Penalties:** Up to €20M or 4% of global annual turnover.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



HIPAA (Health Insurance Portability and Accountability Act):

- **Scope:** Protects Protected Health Information (PHI) in the United States.
- **Application:** Covers healthcare providers, health plans, and their business associates.
- **Requirements:** Administrative, physical, and technical safeguards, along with a breach notification rule.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Key Differences Between GDPR and HIPAA

Aspect	GDPR	HIPAA
Type of data protected	All personal data (name, email, IP address, location, etc.)	Protected Health Information (PHI) related to healthcare
Jurisdiction	Applies to data of EU residents, even if processed outside the EU	Applies to U.S. healthcare providers, insurers, and their vendors
Consent mechanisms	Requires clear, informed, and explicit consent for data collection	Consent depends on treatment, payment, or healthcare operations
Enforcement and penalties	Fines can go up to €20 million (\$23 million) or 4% of global revenue	Tiered penalties ranging from \$100 to \$1.5 million per violation
Data subject rights	Right to access, correct, delete, restrict, and transfer data	Right to access and request corrections to health data (PHI) only



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Intellectual Property Rights

- Intellectual Property Rights (IPR) are legal protections for creations of the mind, crucial for fostering innovation, branding, and protecting unique regional products.
- Key types include patents (inventions), copyrights (creative works), trademarks (brand identifiers), trade secrets (confidential info), and geographical indications (origin-based quality).
- Piracy is the unauthorized reproduction/use of copyrighted content.

Core Intellectual Property Rights (IPR)

- **Patents (Inventions):** Exclusive rights granted for new inventions (products or processes) that are novel, non-obvious, and useful, usually for 20 years.
- **Copyrights (Original Works):** Protects expressions of ideas, including literary, dramatic, musical, and artistic works, software, and films. In India, it covers the author's lifetime plus 60 years.
- **Trademarks (Brand Identity):** Signs, logos, names, or symbols used to distinguish goods or services of one enterprise from others, renewable indefinitely.
- **Trade Secrets (Confidential Information):** Formulae, practices, or methods that provide a competitive edge and are kept confidential.
- **Geographical Indications (GI) (Region-Specific):** Identifies goods (agricultural, natural, or manufactured) having a unique quality or reputation linked to a specific region (e.g., Darjeeling tea).



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Case Studies

- <https://digitaldefynd.com/IQ/cybersecurity-case-studies/>
- <https://www.blackpanda.com/casestudies>
- <https://notiondigitalforensics.com.au/cases/>



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Thank You!



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering

